# SMART CONTRACT SECURITY REVIEW

**Mezo Auth Dev**

*Point-wise Findings with Risk Ratings*

## Scope and Rating Note

Preliminary review of the listed VEMEZO NFT, marketplace administration, treasury/payment components, and x402/Permit2 integration on Mezo Testnet (Chain ID 31611). Risk ratings are initial priority estimates based on component roles and potential impact; they are not proof of an exploitable vulnerability. Contract-level conclusions require verified deployed code and targeted tests.

## Contract Address Register

| Contract / Component | Exact Address | Stated Role |
|---|---|---|
| VEMEZO NFT | 0xaCE816CA2bcc9b12C59799dcC5A959Fb9b98111b | NFT creation and marketplace asset |
| MarketplaceAdmin | 0x1D462522A9f8fbea6c10122dce01E09432A64dBF | Marketplace administration and fee controls |
| MUSD Governance Treasury | 0x000000000000000000000000000000000000dEaD | Treasury destination; confirm intended role |
| Mezo Caller/Token | 0x7B7c000000000000000000000000000000000001 | Pay-per-use integration component |
| MUSD Token / pay-per-use | 0xD88b46ef8444dAA8aa493d714b1124DE75CCa067 | Token configured for pay-per-use flow |
| MUSD Platform / payments | 0x21f7C9fdA5ED418AF3a1C7593dec52142350A0F7 | Payment platform and accounting path |
| Permit2 | 0x000000000022D473030F116dDEE9F6B43aC78BA3 | Token-approval integration dependency |
| x402Permit2Proxy | 0x8dea1b08dc2e1D9b556450f736F19968F367A98d | Custom proxy in x402/Permit2 flow |
| Settlement proxy | 0x402085c248EeA27D92E8b30b2C58ed07f9E20001 | x402 settlement integration |
| MUSD x402 | 0x118917a40FAF1CD7a13dB0Ef56C86De7973Ac503 | MUSD token/component associated with x402 |

## Findings

### F-01 - Treasury destination requires confirmation [MEDIUM RISK]

**Finding:** The listed treasury address is 0x000000000000000000000000000000000000dEaD, commonly associated with a burn or irrecoverable destination. Confirm that this address is intentional for the treasury role and that funds are not expected to be recoverable.

**Recommended validation:** Confirm the intended treasury design and document the destination's role before routing funds.

### F-02 - x402 settlement authorization and call path [HIGH RISK]

**Finding:** The integration lists Permit2, a custom x402Permit2Proxy, and a separate settlement proxy. Incorrect authorization, spender configuration, or call-path assumptions could expose payment transfers to unauthorized use. This is a high-priority review area, not a confirmed exploit.

**Recommended validation:** Verify deployed source and permissions; test unauthorized callers, spender limits, replay protection, and settlement failure paths.

### F-03 - Marketplace administrative controls [HIGH RISK]

**Finding:** MarketplaceAdmin is associated with administrative and fee controls. Excessive or insufficiently constrained privileges could allow unauthorized configuration or fee changes if access checks are defective.

**Recommended validation:** Verify role assignments, access-control checks, fee bounds, and privileged-change events against deployed code.

### F-04 - Payment accounting, withdrawals, and refunds [HIGH RISK]

**Finding:** The MUSD Platform/payments component is identified as a payment path. Accounting errors or unsafe withdrawal/refund behavior could result in incorrect balances or loss of funds if present in implementation.

**Recommended validation:** Test balance invariants, duplicate settlement, failed transfers, refund paths, and withdrawal limits.

### F-05 - Token address consistency across flows [MEDIUM RISK]

**Finding:** Separate MUSD addresses are listed for pay-per-use and x402. Configuration drift or incorrect token selection could cause payments to use an unintended asset.

**Recommended validation:** Verify chain ID 31611 and token addresses at each integration point; reject unexpected token/network configurations.

### F-06 - Pay-per-use caller and token role separation [MEDIUM RISK]

**Finding:** The Mezo Caller/Token and MUSD pay-per-use components are listed separately. The intended distinction between caller/executor and token roles should be confirmed so that direct calls cannot bypass payment authorization.

**Recommended validation:** Trace the deployed call flow and test direct invocation, unauthorized callers, and payment-before-service enforcement.

### F-07 - VEMEZO NFT minting and marketplace permissions [MEDIUM RISK]

**Finding:** For the VEMEZO NFT, mint authorization, token-ID uniqueness, ownership transitions, and marketplace approvals are relevant security properties. No specific NFT exploit is confirmed.

**Recommended validation:** Verify mint access control, uniqueness, transfer hooks, approval scope, and marketplace transfer behavior.

### F-08 - Standard token dependency verification [LOW RISK]

**Finding:** Standard MUSD/MEZO dependencies are lower-priority code-review targets if their official deployment identity and verified source are confirmed. This rating does not establish that any listed address is authentic.

**Recommended validation:** Match addresses and chain ID to official deployment references and inspect verified source before relying on this lower-priority classification.

## Risk Summary

| High | Medium | Low |
|---|---|---|
| F-02, F-03, F-04 | F-01, F-05, F-06, F-07 | F-08 |

## Overall Result

Highest review priority is the x402 authorization/settlement boundary, marketplace administrative controls, and payment accounting/withdrawal behavior because defects in these areas could affect asset movement or funds. The treasury destination and token configuration warrant confirmation. No confirmed exploit is established by this preliminary summary.

## References


• Mezo Testnet contracts reference: https://testnet.mezo.org/docs/users/resources/contracts-reference
• Mezo MUSD payments and x402 documentation: https://mezo.org/docs/fr/docs/developers/getting-started/musd-payments-x402/
• Mezo Testnet Explorer: https://explorer.test.mezo.org/